

Remote Lab Portal

Remediation Report

A response to the White-Box Security Assessment Report (Version 1.0, 22 September 2026) issued by the Information Security Office, DIGITS, Indian Institute of Science.

Prepared for	Information Security Office (ISO), DIGITS, IISc
Prepared by	Remote Lab Portal project team
Date	23 September 2026 (Version 2.0)
Responds to	36 findings raised against commit 3fcbca6
Classification	Confidential - restricted distribution

Headline: all 8 Critical findings and all 12 High findings are now closed or substantially closed. 22 of 36 findings are fully resolved, 8 are partly resolved, and 6 remain open - none of them High or Critical. No open finding allows an unauthenticated person to reach laboratory hardware.

1. Summary

The assessment raised 36 findings, 8 of them Critical, and recommended that the portal not be exposed beyond a closed laboratory network until the Critical items were fixed. This report records what has been done since.

The central problem the assessment identified was that laboratory hardware could be controlled from the network without any account. Someone who could reach the server could obtain the access keys of students running experiments, and then use those keys to upload firmware to a bench, drive its serial connection, watch its camera or shut the session down. That chain has been broken at every link, and the fixes have been confirmed working on the running system rather than only in testing.

Work was carried out on 23 September 2026 across 26 changes. Each change addresses one finding and carries an automated test that was first confirmed to fail against the old code, so the test proves the problem existed and is now gone. The project's automated test suite grew from 152 checks to 274.

This version supersedes the report of the same date, which was issued before the last six fixes were made. One correction is also noted: the summary table in that version stated 17 resolved, 9 partly resolved and 10 open, which does not total 36. The correct figures at that time were 16, 9 and 11, as its own headline stated. The table below is the current position.

Status at a glance

Severity	Raised	Fully resolved	Partly resolved	Open
Critical	8	8	0	0
High	12	10	2	0
Medium	10	4	2	4
Low	1	0	1	0
Informational	5	0	3	2
Total	36	22	8	6

The overall risk rating of Critical was driven by the unauthenticated route to hardware control. That route is closed, and no Critical or High finding now remains open. The project team's assessment is that the residual risk is Low to Medium, and that the six remaining items are ordinary remediation work rather than reasons to withhold the service.

2. Critical findings - all resolved

Each of these was reachable by someone with no account on the portal.

F-01 RESOLVED

What was wrong. The compatibility service for older benches accepted instructions from anyone on the network, with no password, because that behaviour was switched on by default.

What was done. The service now always requires the shared key. The setting that allowed anonymous access can no longer override it, and is off by default so a server that loses its configuration file cannot silently reopen the hole. The service also stopped handing out each bench's individual key to anyone who asked.

F-02 RESOLVED

What was wrong. Anyone could read the access keys of students currently running experiments, together with their names and institutional email addresses.

What was done. These pages now require authentication. Separately, student names and email addresses are no longer sent to the benches at all - a bench is told which key is valid and when it expires, identified only by booking code.

F-03 RESOLVED

What was wrong. Anyone holding an access key could upload firmware to a physical bench. No account was needed. The code claimed to check ownership but the check was never written.

What was done. Uploading now requires the student who booked that bench to be signed in. The file size is also limited before the file is read into memory, and refused attempts are recorded.

F-04 RESOLVED

What was wrong. Anyone holding an access key could take over a student's live experiment, including the serial console and the debugger.

What was done. The live connection now requires the owning student to be signed in, and this is re-checked on every single command rather than only when the connection opens - so an administrator ending a session takes effect immediately.

F-06 RESOLVED

What was wrong. The administrator sign-in page applied no lockout after repeated failures, and its error messages revealed when a password was correct - for any account, not just administrators.

What was done. Both sign-in pages now share one routine. Lockout applies to both, every failure produces an identical response, and failed attempts are recorded. A student signing in at the staff page is simply sent to their own dashboard rather than being told their password was right.

F-07 RESOLVED

What was wrong. If the configuration file was missing, the system started anyway using default passwords that are published in the source code.

What was done. The system now refuses to start on a missing, placeholder or too-short key. It also no longer builds itself as a side effect of being imported, which is what made the failure reachable.

F-10 RESOLVED

What was wrong. A bench's network address could be set by anyone, and the portal would then send requests to whatever address was given - including internal services that trust it.

What was done. Addresses are now checked against the laboratory network and a list of permitted ports. The address a bench actually connects from takes priority over the address it claims, and the portal no longer follows redirections from a bench.

F-14 RESOLVED

What was wrong. Anyone could end any student's live session, and doing so destroyed the student's booking so they could not restart it.

What was done. Only the bench that owns a session can end it, proven with that bench's own key. Ending a session no longer cancels the booking, so the slot stays usable.

3. Other findings resolved

ID	Severity	What was done
F-05	High	A second, unprotected copy of the bench camera feed existed alongside the protected one. It has been removed.
F-08	High	Session cookies are marked secure, the site is served over HTTPS, and the application is configured to sit behind the web server correctly. A change restricting the application to local connections only is prepared and awaits a scheduled maintenance window.
F-12	High	The live-instrument connection accepted connections from any website on the internet. It now accepts them only from the portal's own address.
F-23	High	Five software components carried eleven published vulnerabilities. All have been upgraded and the vulnerability scanner now reports none. The upgrade was tested in an isolated copy before being applied.
F-29	High	The service ran as a staff member's own login account, which gave it access to that person's files and privileges. A restricted account with no login rights is prepared, along with substantially tighter operating-system restrictions; this awaits a scheduled maintenance window.
F-20	Medium	The sign-in page could be tricked into sending a student to an outside website immediately after they signed in, which could be used for convincing phishing. Only addresses on the portal itself are now accepted.
F-25	Medium	The thirty-minute inactivity sign-out signed the user out and then crashed, showing a server error instead of the sign-in page. Fixed.
F-30	Medium	Server addresses and a reference to a weak password have been removed from the project documentation and from its history.
F-11	High	Information a bench sends back - register names, disassembly, variable names and values - was placed into the debugger panel as page content rather than as plain text, so a bench that had been tampered with could have run code inside a student's browser, within their signed-in session. All such text is now made safe at the point it is displayed. The same code existed in two pages and both were corrected.
F-13	High	Temporary passwords and password-reset links were written into the server log and displayed on screen to the administrator. Neither is now recorded or shown; the log carries only a reference number, the recipient and the subject, which is enough to trace a message without disclosing it.
F-19	High	Charting, icons, fonts and the live-instrument library were downloaded from four external services on every page load, with no check that they were unaltered - and the charting library was requested without naming a version at all, so the portal accepted whatever those services published that day. All are now served by the portal itself from files held within the project, with each file's origin and checksum recorded. The browser security policy no longer permits any external source. A side benefit: the instrument pages now work on a closed network, which they could not have done before.
F-27	High	Upload size is limited before the file is read into memory. The permitted file types are now determined by the bench record rather than by a value the uploader supplies, so the restriction can no longer be chosen by the person being restricted. The result of the virus scan is recorded against every accepted upload, so 'scanned and clean' is now distinguishable from 'never scanned'.
F-28	High	The optional demonstration data gave all three sample accounts one fixed password, which also appeared in the project documentation. Each account now receives its own random password, displayed once when the command is run. The live database was checked and holds no demonstration accounts.

ID	Severity	What was done
F-09	Medium	A page on another website could cause a signed-in user's browser to carry out actions on the portal without their knowledge - including administrator actions such as creating users or devices. Every form and every instrument command now carries a single-use ticket that only the portal's own pages can obtain, and any request arriving without one is refused. Sign-out was also changed from a link to a button, because a link can be triggered by any page that a browser visits.

4. Findings partly resolved

In each of these the most serious part has been addressed and a smaller part remains.

ID	Severity	Position
F-15	High	Benches can no longer be registered anonymously, which removed the practical route to flooding the database. A hard limit on the number of benches is still to be added.
F-17	High	Sign-in attempt limits have been added at the web server, and the account lockout fixed under F-06 now works on both sign-in pages. Limits on the remaining pages are still to be added.
F-21	Medium	Sign-in responses no longer reveal which email addresses have accounts. The separate concern - that repeated failures can be used to lock a named person out deliberately - remains.
F-22	Low	Student names and email addresses are no longer sent to benches. A written retention period for session and upload records is still to be defined.
F-31	Medium	Failed sign-ins, lockouts, refused uploads and refused bench addresses are now recorded, none of which were before. Recording the source address with each entry, sending logs off the machine, and alerting remain.
F-33	Info	The two previously unpinned components are now fixed to exact versions. A full verified dependency lock file is still to be produced.
F-35	Info	Superseded and backup files have been removed from the project. Two duplicate copies of the live-instrument code still exist.
F-36	Info	Automated security tests now exist for every Critical finding and run with the normal test suite. Two-factor sign-in for administrators, and an automated build pipeline, remain outstanding.

5. Findings still open

Six findings remain. None is Critical or High. None can be reached by someone without an account, none gives control of laboratory hardware, and none exposes personal data. They are scheduled rather than urgent.

ID	Severity	What remains
F-16	Medium	Two students booking the same slot at the same instant can both succeed, because the check and the booking are not a single indivisible step. The consequence is a double booking to be sorted out by staff, not a security breach.
F-18	Medium	Passwords need only be eight characters, with no check against known breached passwords. A limit on how often a password may be changed is written in the configuration but never actually applied.
F-24	Medium	Two administrator forms do not check that a value expected to be a number is one, so a malformed entry produces a server error page rather than a polite message. No data is exposed by it.
F-26	Medium	The bulk user import honours a 'role' column, so a spreadsheet prepared by someone else could create administrator accounts without the member of staff importing it noticing. It requires an administrator to perform the import.
F-32	Info	Session keys are shorter than ideal for a value that controls physical equipment. They are not guessable in practice.
F-34	Info	The example code supplied for the benches compares its key in a way that could in principle leak information through timing. The portal's own comparisons are already done safely. Not practically exploitable over a network.

The project team proposes to address F-26 next, as the only remaining item by which a person could gain administrator rights, followed by F-18, F-16 and F-24, and then the two informational items. A verification review is requested once these are complete.

6. Problems found during remediation

Seven problems came to light during this work that were not in the assessment. They are recorded here for completeness.

Live secrets were briefly published

While preparing the fixes, a routine commit accidentally included a backup copy of the live configuration file, and it was pushed to a public code repository. It was public for approximately thirty minutes. The session key and the bench network key were rotated the same day, the repository was made private, and the file was permanently removed from the project's history. One credential, an email account password not under this project's control, has been referred to its owner for rotation. The gap that allowed it - the ignore rules did not cover backup copies of the configuration file - has been closed.

Sign-out did not invalidate other sessions

A recently added feature intended to sign a user out everywhere was written in the wrong order and never actually took effect, despite its description stating otherwise. Fixed, with a test.

An undeclared software requirement

The application used a component that was never listed among its requirements. It happened to be installed on the live server, so this was invisible - but a rebuild from the project files would have produced a system that could not start. Now declared.

The charting library had no version fixed

The portal requested its charting library without naming a version, so on every page load it accepted whatever that external service happened to be publishing - including new major versions that had never been tested against this portal. It is now fixed at the version that was actually in use, and held within the project rather than fetched.

Two pages ran different versions of the same library

The mathematics-rendering library was already held within the project and used by the laboratory page, but the experiment page was still downloading a different, older version from the internet. The two pages were therefore running different versions of it. Both now use the local copy.

The database file can be read by any account on the server

The file holding user records, including password hashes, permits any local account on the server to read it. Correcting this is tied to the restricted-service-account change and will be done at the same time, because restricting the file before that change would stop the service starting.

The web server did not support live instruments

Serial, the plotter, the oscilloscope and the debugger could not work through the public web address, because the web server was not configured to carry that type of connection. The page still loaded and the camera still worked, so the fault was not obvious. Corrected, and documented so it is recognised in future.

7. How the work was verified

Three forms of evidence support the statements in this report.

Tests written before fixes. For each finding, an automated test was written first and confirmed to fail against the unfixed code, then confirmed to pass afterwards. This demonstrates both that the problem was real and that

it is gone. The suite now runs 274 checks, up from 152.

Checks against the running system. After deployment, the four most serious routes were tried against the live server. Each was refused: anonymous access to the bench service, anonymous access to bench status, the removed camera page, and unauthenticated firmware upload.

Independent tooling. The dependency vulnerability scanner reports no known vulnerabilities, against eleven before. The operating-system service definition was validated with the system's own checking tool. Every file now served in place of an external download was checked to be the genuine library, and its checksum recorded in the project.

Limits of this verification. Two things need confirmation by a person rather than by a test, because they cannot be tested automatically here. The first - that a laboratory session still works end to end, and that the changed sign-out control behaves correctly - was checked on the live system after the cross-site protection was added, and passed. The second - that the instrument pages still display correctly now that fonts and icons are served by the portal rather than fetched from outside - has not yet been confirmed at the time of writing. Automated checks confirm every such file is present and served, but a visual check remains outstanding and is listed in section 8. Nothing in that change affects access control; the risk if it is wrong is cosmetic.

Three tests in the suite fail, all concerning time-zone handling of late-evening booking slots. They pre-date this work, are unrelated to security, and are scheduled for correction.

8. Operational actions outstanding

Action	Owner	Status
Rotate the shared email account password	Mail account owner	Done
Restrict the database file to the service account	System administrator	With the service-account change
Apply the restricted service account and tighter system restrictions	System administrator	Prepared, awaiting window
Restrict the application to local connections only	System administrator	Prepared, awaiting window
Narrow the permitted bench network range in configuration	System administrator	Pending
Confirm the instrument pages display correctly after F-19	Project owner	Outstanding
Correct the three time-zone test failures	Developer	Pending
Request a verification review	Project owner	After remaining Medium items

Prepared 23 September 2026. This report describes the state of the system on that date and should be read alongside the original assessment.